

Exercise 1: The Blind Server (Middleware Ordering)

Context: Assessment outcomes must stay confidential. The route GET /api/assessments/results returns a placeholder JSON body for now (you will replace it with real persistence and DTOs in later modules). Below is starter Program.cs from a prior check-in. Run it, hit the route anonymously, then read the file top to bottom and decide what should happen for a protected read versus what actually happens.

Predict before you change code

[!CAUTION] Trace one incoming GET in order: which app.Use... / Map... lines run, and in what sequence? Where does the response get committed? Write your prediction in one sentence, then run the app and compare.

// Starter pipeline (do not assume this order is correct)

[!NOTE]

Minimal API Setup

```
var builder = WebApplication.CreateBuilder(args);
var app = builder.Build();
app.UseRouting();
app.MapGet("/api/assessments/results", () => Results.Ok(new
{
    courseCode = "CS-101",
    studentId = "S-001",
    letterGrade = "A"
}));
app.UseAuthentication();
app.UseAuthorization();
app.Run();
```

Your task: secure the pipeline

Rewrite Program.cs so GET /api/assessments/results is not anonymous: unauthenticated callers get 401, not the JSON body. You keep the same placeholder response for callers who are allowed through (your cohort's auth scheme may be minimal this early—follow your facilitator).

Work from your template's usual Program.cs shape; do not paste a full solution from elsewhere unless your facilitator green-lights it. Use this scaffold and fill the TODOs from your understanding of the pipeline:

```
var builder = WebApplication.CreateBuilder(args);
```

```
// Services: add authentication / authorization services if your template or facilitator requires them for this exercise
```

[!NOTE]

Pipeline Configuration and Todo Steps

```
var app = builder.Build();

// TODO 1: Register routing in the pipeline where it belongs for
your app.

// TODO 2: Register authentication and authorization in the
pipeline where your template and facilitator
// expect them for a protected minimal API route.

// TODO 3: Map GET /api/assessments/results with the same response
body as the starter, but require
// authorization for that route.

app.Run();
```

Run / verify / common failure

- Run: dotnet run
- Check (preferred before Scalar): Browser GET <http://localhost:5000/api/assessments/results> with no login or bearer token.
- Expected: 401 Unauthorized not 200 with JSON, not 404.
- After Scalar exists: Same request via Scalar Try it; confirm status 401.
- Common failure 404: Terminal middleware or branch ordering—re-read the middleware / request-pipeline section in Module 4 ASP.NET Core Fundamentals (your Essentials reading).
- Common failure still 200 with body on anonymous GET: Middleware that should run for this route is not in the active pipeline path—trace order again or ask for a hint in the room.